

BÀI 3

Dò tìm lỗ hổng bảo mật
thông tin

B. Quét mạng

Nội dung

Quét hệ thống mạng

- Khái niệm chung
- Quét hệ thống
- Một số khái niệm cơ bản
- Các kỹ thuật quét mạng
 - Kỹ thuật quét port
 - Biện pháp đối phó quét port
 - Quét điểm yếu
 - Vẽ lược đồ mạng
 - Sử dụng Proxy
 - Ẩn danh
 - Địa chỉ IP giả
- Biện pháp phòng chống
- Bài tập

Khái niệm chung

IP address and
open ports of Live Hosts



Operating Systems
and System Architecture



Services
Running on Hosts



- Scanning refers to a set of procedures for **identifying hosts, ports, and services in a network**
- Scanning is one of the **components of intelligence gathering** for an attacker to create a profile of the target organization

Attacker



Sends TCP/IP probes

Gets network Information



Network

Khái niệm chung

Types of Scanning



Port Scanning

A series of messages sent by someone attempting to break into a computer to learn about the computer's network services

Each message is associated with a "well-known" port number



Vulnerability Scanning

The automated process of proactively identifying vulnerabilities of the computing systems present in a network



Network Scanning

A procedure for identifying the active hosts on a network

Either for the purpose of attacking them or for network security assessment

Khái niệm chung

Scanning Methodology

Check for
Live
Systems



Check for
Open
Ports



Banner
Grabbing



Prepare
Proxies



Draw
Network
Diagrams



Scan for
Vulnerability

Quét hệ thống

Checking for Live Systems - ICMP Scanning

- Ping scan involves sending **ICMP ECHO requests** to a host. If the host is live, it will return an ICMP ECHO reply
- This scan is useful for **locating active devices** or determining if **ICMP is passing through a firewall**

Source	Destination	Summary
192.168.168.3	192.168.168.5	ICMP: Echo
192.168.168.5	192.168.168.3	ICMP: Echo Reply



Source
192.168.168.3

ICMP Echo Request



ICMP Echo Reply



Destination
192.168.168.5

The ping scan output using Nmap:

```
#nmap -sP -v 192.168.168.5
```

```
starting nmap 5.21 (http://nmap.org) at 2010-07-11 16:30 EDT
```

```
Host 192.168.168.5 appears to be up.
```

```
MAC Address: 00:E8:48:12:CD:8A (Hewlett Packard)
```

```
Nmap finished: 1 IP address (1 host up) scanned in 0.889 seconds
```

```
Raw packets sent: 5 (30B) | Rcvd: 2 (25B)
```



Quét hệ thống

Ping Sweep

- Ping sweep is used to determine the **live hosts from a range of IP addresses** by sending ICMP ECHO requests to multiple hosts. If a host is live, it will return an ICMP ECHO reply
- Attackers use ping sweep to create **inventory of live systems** in a network

The ping sweep output using Nmap:

```
nmap -sP -PE -PA21,23,80,3389 192.168.168.1-50
```

```
Starting Nmap 5.21 ( http://nmap.org ) at  
2010-07-13 14:16 EDT
```

```
Nmap scan report for 192.168.168.1
```

```
Host is up (0.00s latency).
```

```
MAC Address: 00:A8:5A:E0:83:05 (Hewlett  
Packard)
```

```
Nmap scan report for 192.168.168.2
```

```
Host is up (0.016s latency).
```

```
MAC Address: 00:01:6B:0A:8E:15 (Foxconn)
```

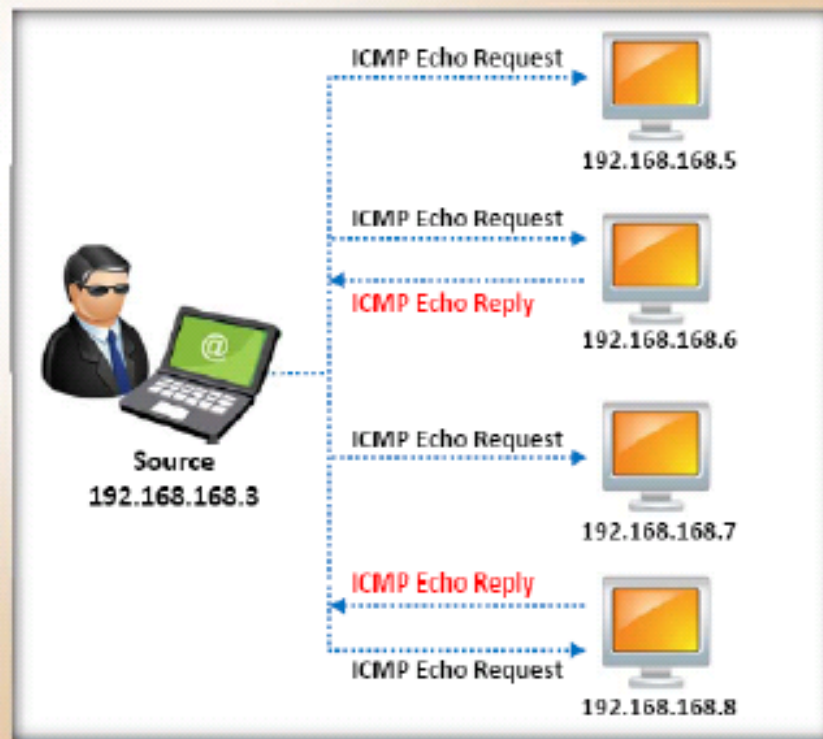
```
Nmap scan report for 192.168.168.4
```

```
Host is up (0.00s latency).
```

```
MAC Address: 00:2A:B9:03:DD:80 (Dell)
```

```
Nmap scan report for 192.168.168.6
```

```
Host is up (0.00s latency).
```



Quét hệ thống

Ping Sweep Tools



Colasoft Ping Tool

<http://www.colasoft.com>



Ping Scanner Pro

<http://www.digilextechnologies.com>



SolarWinds Standard Edition

<http://www.solarwinds.com>



Ultra Ping Pro

<http://ultraping.netfirms.com>



Utility Ping

<http://www.wavget.com>



PingInfoView

<http://www.nirsoft.net>



Visual Ping Tester

<http://www.pingtester.net>



PacketTrap pt360

<http://www.packettrap.com>

Một số khái niệm cơ bản

Three-Way Handshake

TCP uses a **three-way handshake** to establish a connection between server and client

1

The Computer A (10.0.0.2) Initiates a connection to the server (10.0.0.3) via a packet with only the **SYN** flag set

2

The server replies with a packet with both the **SYN** and the **ACK** flag set

3

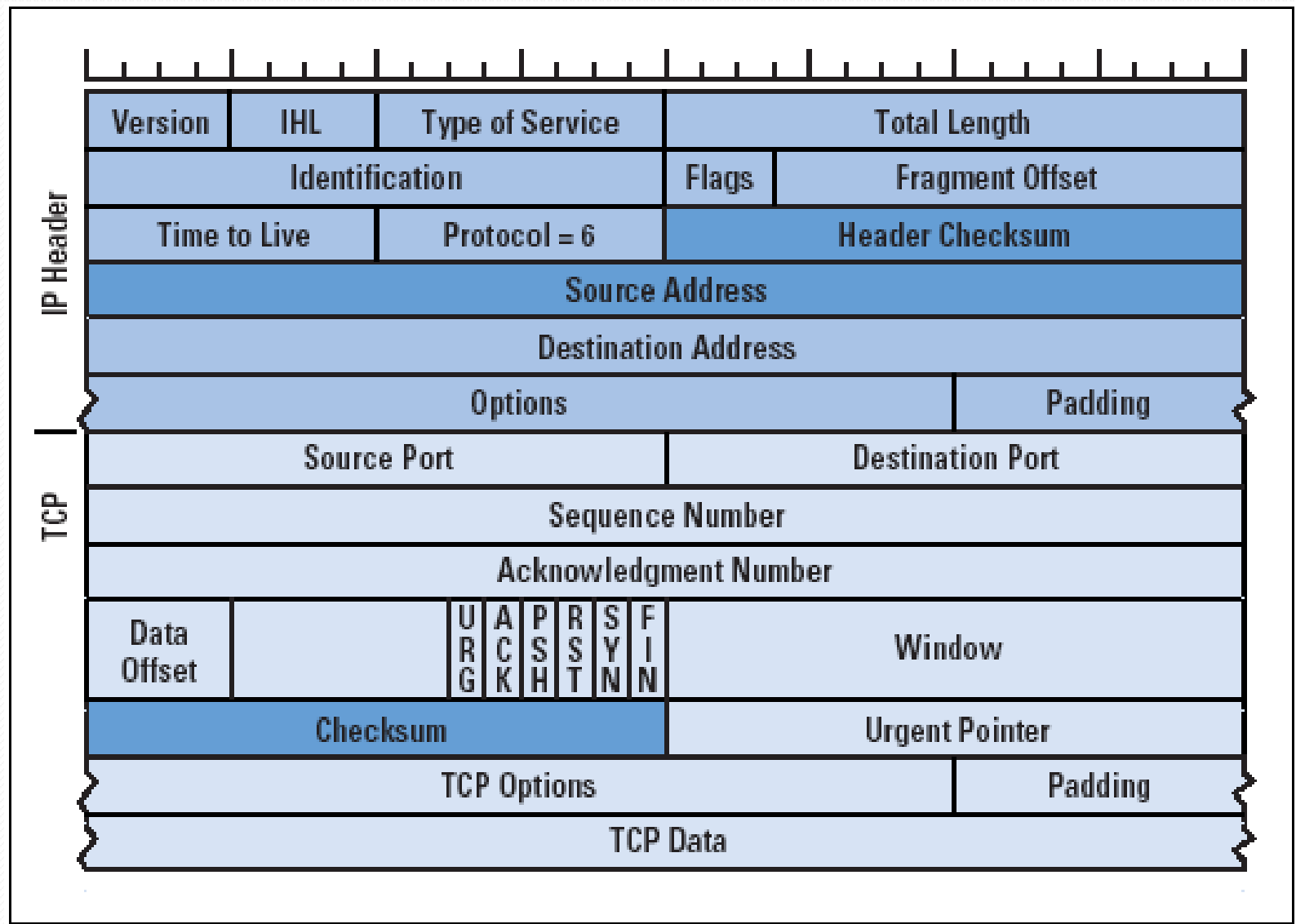
For the final step, the client responds back to the server with a single **ACK** packet

4

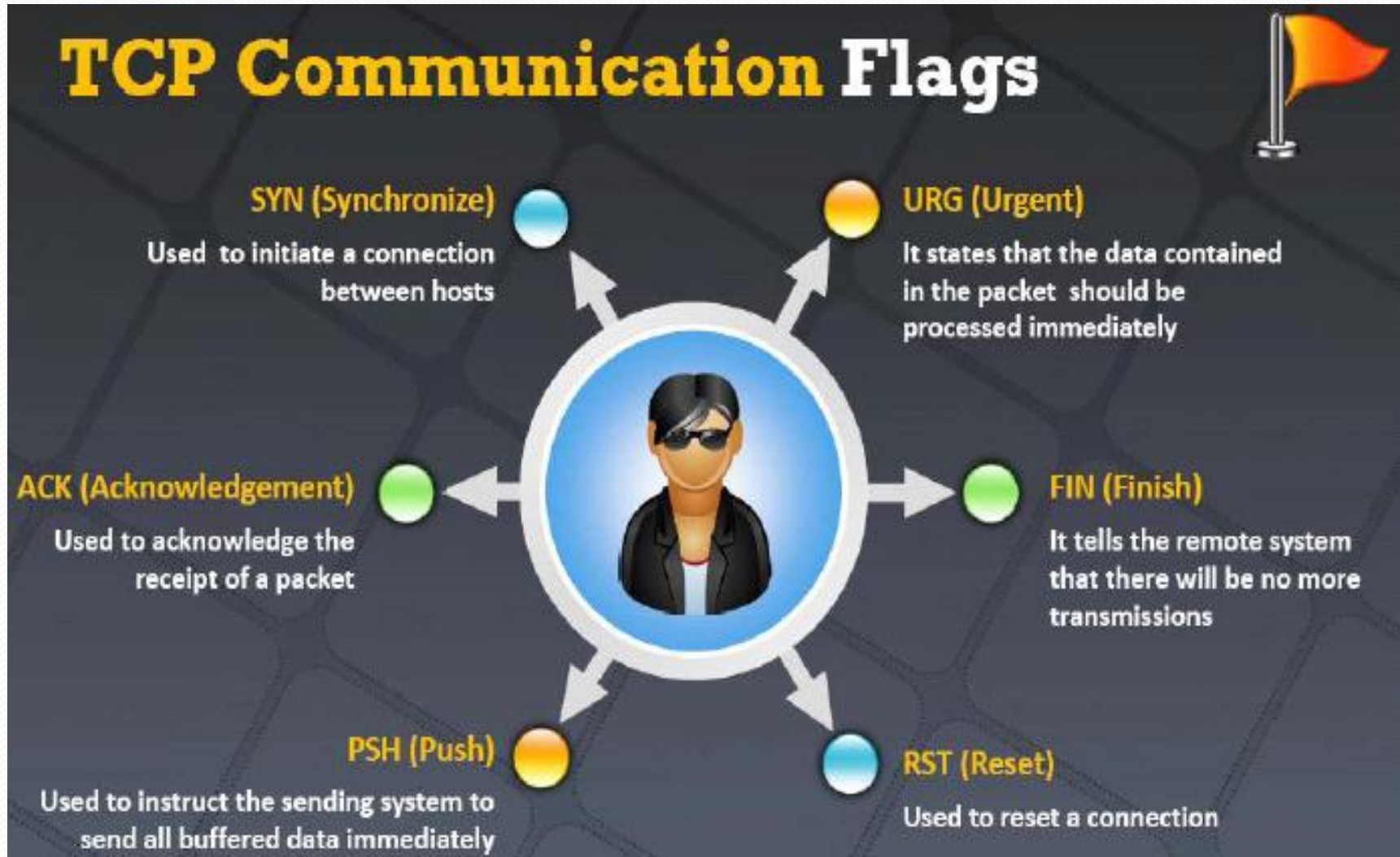
If these three steps are completed without complication, then a TCP connection is established between the client and the server



Một số khái niệm cơ bản



Một số khái niệm cơ bản



Một số khái niệm cơ bản

Create **Custom Packet** using TCP Flags

The screenshot shows the 'Komodia's packet crafter' application window. It features a 'TCP parameters' dialog box with the following fields and options:

- Source IP:** 192 . 168 . 168 . 10
- Destination IP:** 192 . 168 . 168 . 11
- Source port:** 50
- Destination port:** 80
- Flags:** ☐ URG ☐ ACK ☐ PSH ☐ RST ☐ SYN ☐ FIN
- Sequence:** 0
- Acknowledge:** 0
- Window:** 1500
- Urgent:** 0
- Offset:** 5
- TCP checksum:** 0 ☒ Default checksum

Buttons for 'Send' and 'Back' are visible in the dialog box. The main window also has a 'Send' button on the right side.

Một số khái niệm cơ bản

Hping2 / Hping3



It is a command line packet crafter for the TCP/IP protocol



Tool for security auditing and testing firewall and networks



It runs on both Windows and Linux operating systems



hping3 is a scriptable TCL language command line tool compatible with hping2



Một số khái niệm cơ bản

Hping Commands

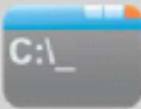


ICMP Ping

```
hping3 -1 10.0.0.25
```

SYN scan on port 50-60

```
hping3 -8 50-56 -S 10.0.0.25 -V
```



ACK scan on port 80

```
hping3 -A 10.0.0.25 -p 80
```

FIN, PUSH and URG scan on port 80

```
hping3 -F -p -U 10.0.0.25 -p 80
```



UDP scan on port 80

```
hping3 -2 10.0.0.25 -p 80
```

Scan entire subnet for live host

```
hping3 -1 10.0.1.x --rand-dest -I eth0
```



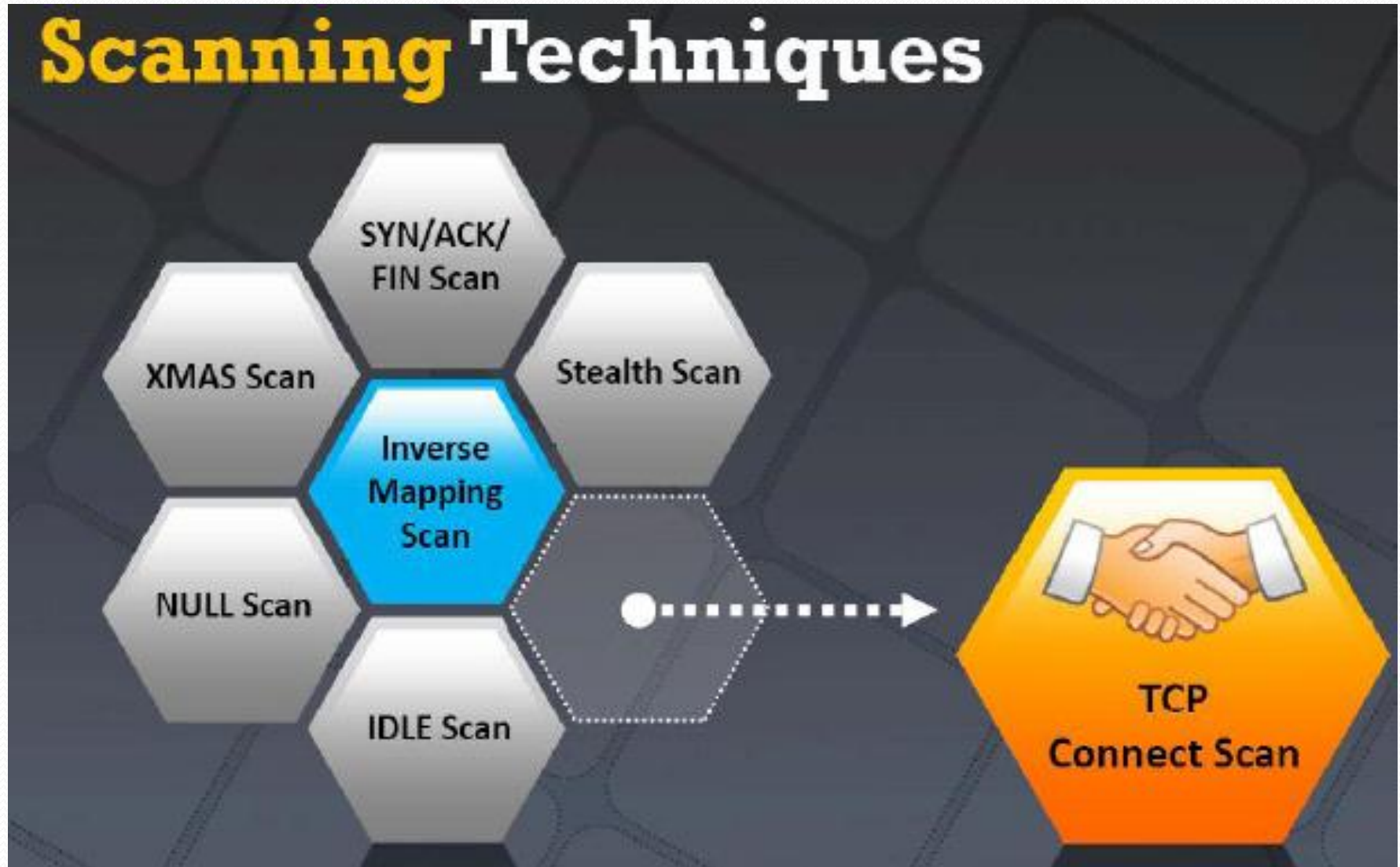
Collecting Initial Sequence Number

```
hping3 192.168.1.103 -Q -p 139 -s
```

Intercept all traffic containing HTTP signature

```
hping3 -9 HTTP -I eth0
```

Kỹ thuật quét port



Kỹ thuật quét port

TCP Connect / Full Open Scan

- TCP Connect scan detects when a port is open by completing the **three-way handshake**
- TCP Connect scan establishes a full connection and tears it down by sending a **RST packet**



Kỹ thuật quét port

Stealth Scan (Half-open Scan)

Attackers use **stealth scanning techniques** to bypass firewall rules, logging mechanism, and hide themselves as usual network traffic



1 The client sends a single **SYN** packet to the server on the appropriate port.

3 If the server responds with an **RST** packet, then the remote port is in the "closed" state



2 If the port is open then the server responds with a **SYN/ACK** packet

4 The client sends the **RST** packet to close the initiation before a connection can ever be established

Kỹ thuật quét port

Xmas Scan



- Xmas scan sends a TCP frame to a remote device with **URG**, **ACK**, **RST**, **SYN**, and **FIN** flags set
- FIN scan only with OS TCP/IP developed according to **RFC 793**
- It will not work against any current version of **Microsoft Windows**



The Xmas scan output using Nmap:

```
# nmap -sX -v 10.0.0.8

Starting nmap 5.21 (http://nmap.org at 2010-07-11 16:30 EDT)
Initiating XMAS Scan against 10.0.0.8 [1663 ports] at 21:18
The XMAS Scan took 1.55s to scan 1663 total ports
Host 10.0.0.8 appears to be up ... good.
Interesting ports on 10.0.0.8:
(The 1654 ports scanned but not shown below are in state: closed)
PORT      STATE      SERVICE
21/tcp    open|filtered  ftp
22/tcp    open|filtered  ssh
79/tcp    open|filtered  finger
110/tcp   open|filtered  POP3
514/tcp   open|filtered  Shell
#
```

Kỹ thuật quét port

FIN Scan



- FIN scan sends a TCP frame to a remote device with **FIN** flag set
- FIN scan only with OS TCP/IP developed according to **RFC 793**
- It will not work against any current version of **Microsoft Windows**

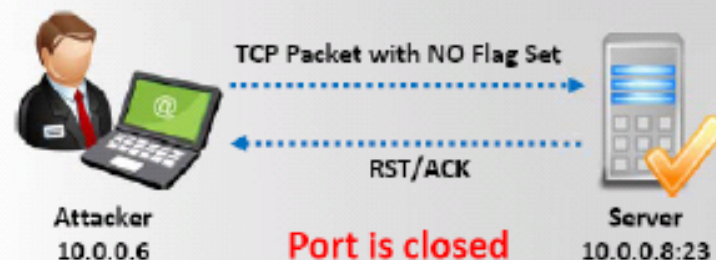
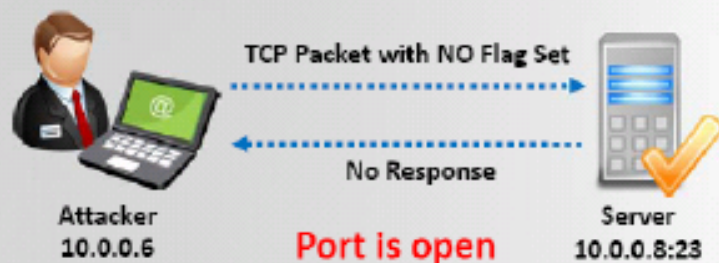
```
nmap -sF 192.168.168.13
```

```
Starting Nmap 5.21 ( http://nmap.org ) at 2010-07-15 20:51 EST
Nmap scan report for 192.168.168.13Host is up
(0.000052s latency).
All 1000 scanned ports on 192.168.168.13 are closed
MAC Address: 00:15:58:A1:07:B2 (Foxconn)
Nmap done: 1 IP address (1 host up) scanned in 5.55
seconds
```

In FIN scan, attackers send a TCP frame to a remote host with **only FIN flags set**

Kỹ thuật quét port

NULL Scan



- NULL scan only works if OS' TCP/IP implementation is developed according to **RFC 793**
- It will not work against any current version of **Microsoft Windows**

```
nmap -sN 192.168.168.13
```

```
Starting Nmap 5.21 ( http://nmap.org ) at 2010-07-15  
21:10 EST  
Nmap scan report for 192.168.168.13 Host is up (0.00s  
latency).  
All 1000 scanned ports on 192.168.168.13 are  
open|filtered  
MAC Address: 00:15:58:A1:07:B2 (Foxconn)  
Nmap done: 1 IP address (1 host up) scanned in 29.03  
seconds
```

In NULL scan, attackers send a TCP frame to a remote host with **NO Flags**

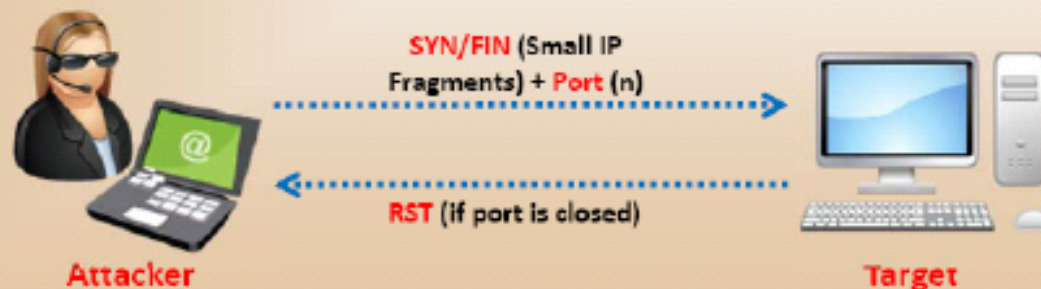
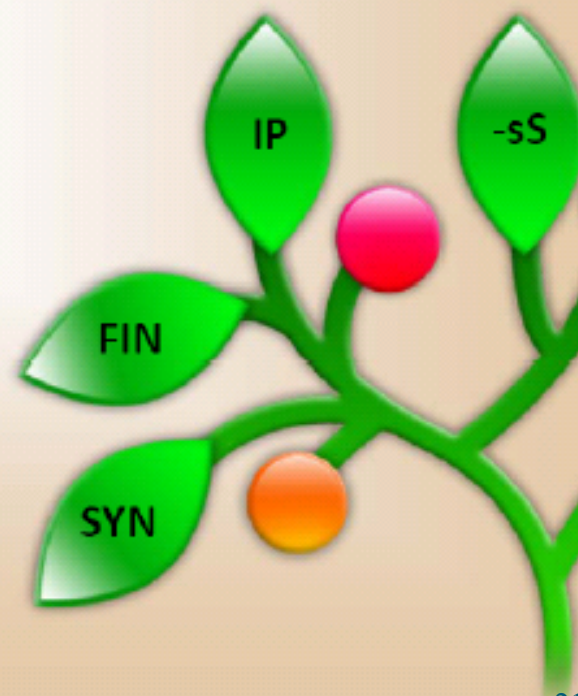
Kỹ thuật quét port

SYN/FIN Scanning Using IP Fragments

- It is not a new scanning method but a **modification** of the earlier methods
- The **TCP header** is split up into several packets so that the packet filters are not able to detect what the packets intend to do

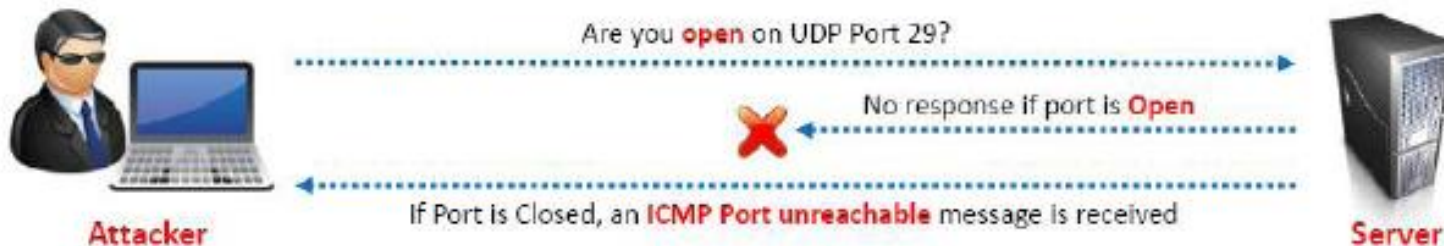
```
Command Prompt

C:\>nmap -sS -T4 -A -f -v 192.168.168.26
Starting Nmap 5.21 ( http://nmap.org ) at 2010-11-29
13:05 India Standard Time
Initiating SYN Stealth Scan at 13:05
Scanning 192.168.168.26 [1000 ports]
Discovered open port 139/tcp on 192.168.168.26
Discovered open port 135/tcp on 192.168.168.26
Completed SYN Stealth Scan at 13:05, 1.16s elapsed
(1000 total ports)
```



Kỹ thuật quét port

UDP Scanning



UDP Port Open

- There is no **three-way TCP handshake** for UDP scan
- The system does not respond with a message when the port is **open**

UDP Port Closed

- If a UDP packet is sent to open port, the system responds with **ICMP port unreachable message**
- Spywares, Trojan horses, and other malicious applications use **UDP** ports

Kỹ thuật quét port

Inverse TCP Flag Scanning

- Attackers send TCP probe packets with various TCP flags (FIN,URG,PSH) set or with no flags, **no response means port is open and RST/ACK means the port is closed**



Attacker

PORT IS OPEN

Probe Packet (FIN/URG/PSH/NULL) →



No Response



Target Host



Attacker

PORT IS CLOSED

Probe Packet (FIN/URG/PSH/NULL) →



RST/ACK



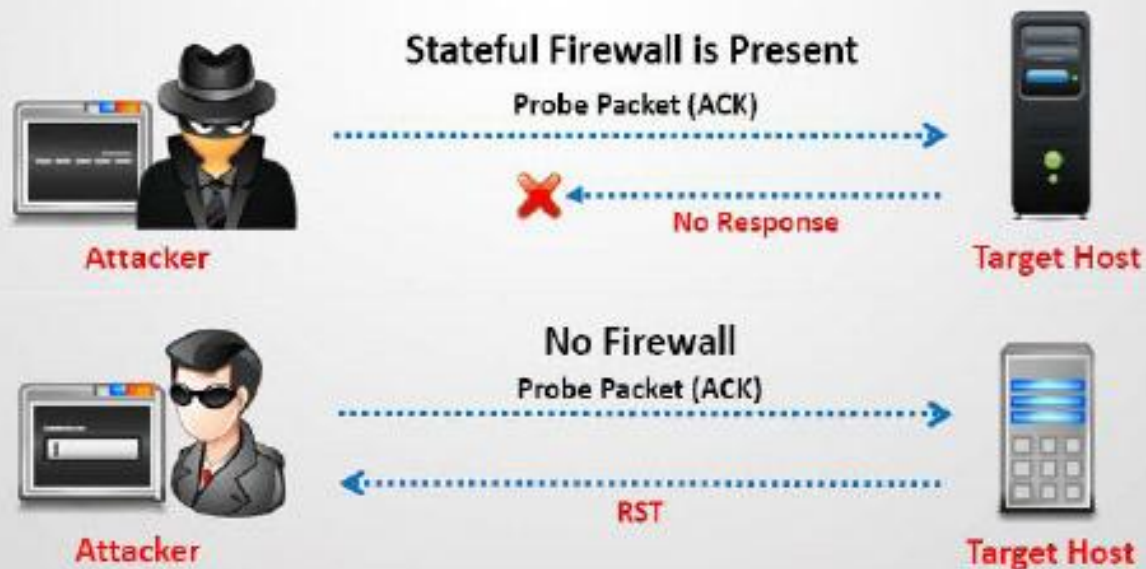
Target Host

Kỹ thuật quét port

ACK Flag Scanning

- Attackers send an **ACK probe packet** with random sequence number, **no response means port is filtered** (stateful firewall is present) and **RST response means the port is not filtered**

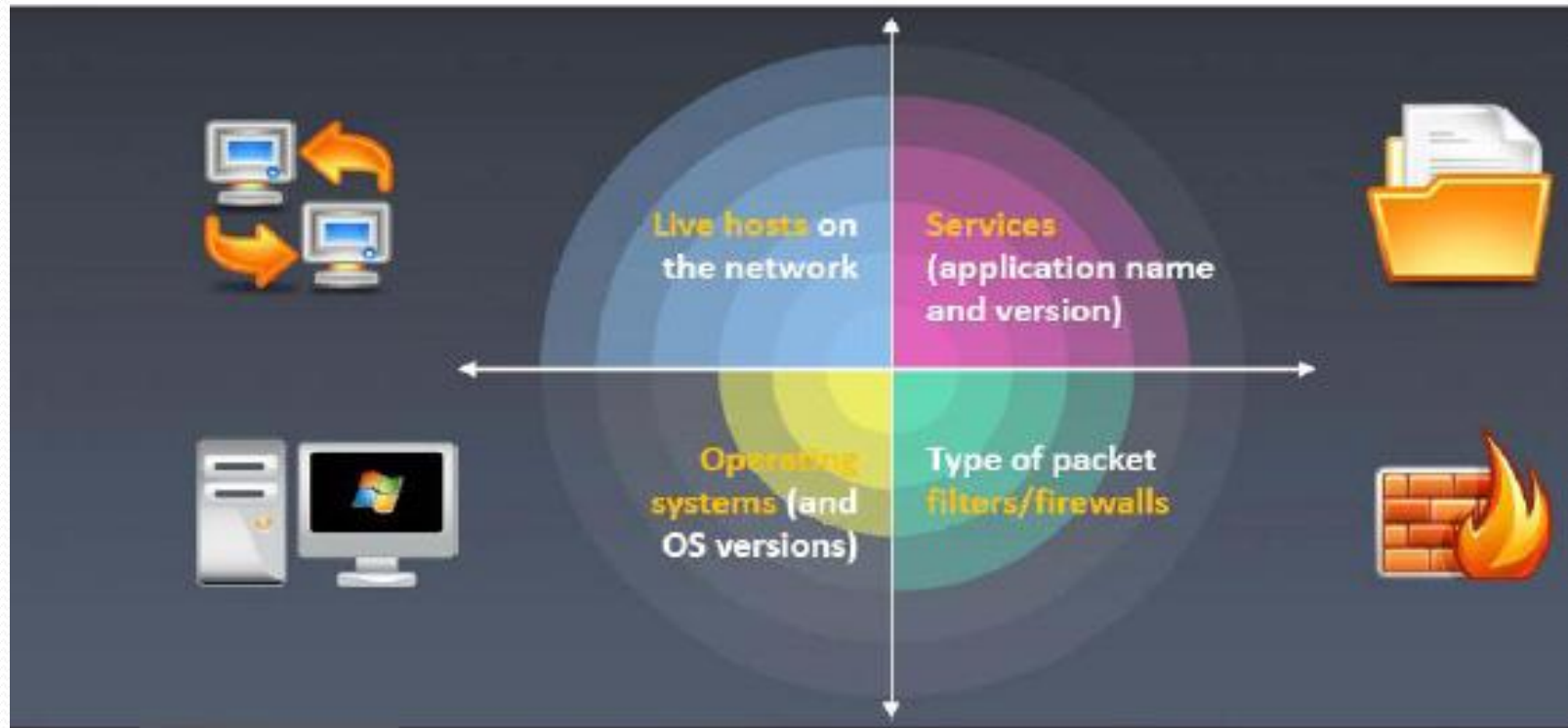
```
nmap -sA -P0 10.10.0.25  
Starting nmap 5.21 (http://nmap.org) at 2010-05-16 12:15 EST  
All 529 scanned ports on 10.10.0.25 are: filtered
```



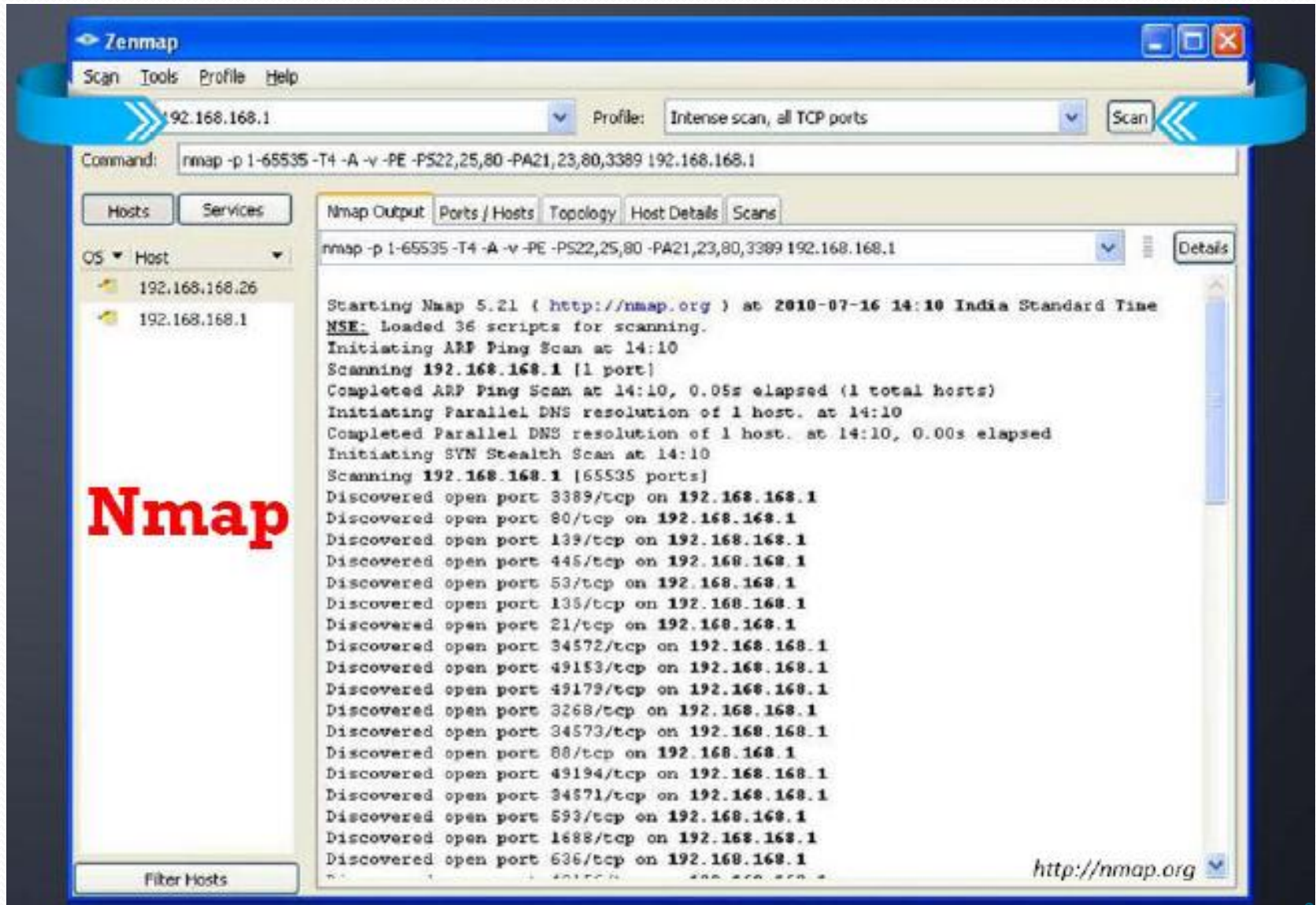
Kỹ thuật quét port

Scanning Tool: Nmap

- Nmap is a free open source utility **for network exploration**
- Network administrators can use Nmap for **network inventory**, managing service u schedules, and **monitoring host or service uptime**
- Attacker can use Nmap to extract information such as:



Kỹ thuật quét port



Kỹ thuật quét port

Scanning Tool: NetScan Tools Pro

The screenshot displays the NetScan Tools Pro 10.61 (TM) application window. The interface includes a menu bar (File, View, Accessibility, Help), a toolbar with buttons for Welcome, Automated, and Tools, and a left-hand sidebar listing various network tools. The main window is titled "Port Scanner" and contains a warning: "Use this tool to detect open TCP or UDP ports on a target computer. NEVER scan a computer you do not own or have the owner's permission to scan." The "Target Hostname or Start IP Address" is set to 192.168.0.243, and the "Start Port" is 1. The "End IP Address" is 192.168.0.240, and the "End Port" is 1024. The "Scan Single Host" option is selected. The "Target Computer List" shows three results: 00080 - TCP - http, 00139 - TCP - netbios-ssn, and 00515 - TCP - printer. The "Analyzing TCP SYN Half Open Connect Scan Results..." section shows the total scan time (13.890 seconds), total TCP ports scanned (1024), and total TCP displayed responses (3). The results for 192.168.0.243 indicate three active TCP ports: 80 (Web server), 139 (NetBIOS Session Service), and 445 (unprotected Windows computer).

NetScanTools Pro 10.61 (TM)

File View Accessibility Help

Welcome
Automated
Tools

NetBIOS Info-Shares/Sy
NetBIOS Info-Advanced
NetScanner (Ping Sweep)
Network Statistics
OS Fingerprinting
Packet Generator
Packet Viewer
Ping
Port Scanner
Promiscuous Mode Scan
Realtime Black List Check
RFC Reference
RPC Info
Simple Services
SMTP Email Generator/F
SNMP
Subnet Calculator
TCP Term
TimeSync
Traceroute

Optional Tools
Online
Program Info

For Help, press F1

Port Scanner Use this tool to detect open TCP or UDP ports on a target computer.
NEVER scan a computer you do not own or have the owner's permission to scan.

Target Hostname or Start IP Address: 192.168.0.243
Start Port: 1
End IP Address: 192.168.0.240
End Port: 1024

Scan Single Host
Scan IP Range
Show non-responding ports

See right hand window!

Scan Stop
Sequential Port Scan
Edit... Setup
Targets Ports
WinPcap Interface IP: 192.168.0.202
Create Reports
Connect Timeout (ms): 300
Wait After Connect (ms): 3000

Target Computer List

- 192.168.0.243
 - 00080 - TCP - http
 - 00139 - TCP - netbios-ssn
 - 00515 - TCP - printer

Analyzing TCP SYN Half Open Connect Scan Results...

Total Scan Time = 13.890 seconds
TCP Ports Scanned: 1024
Total TCP Displayed Responses: 3

192.168.0.243--This IP has 3 active TCP port(s) in the port range scanned. The rest of ports scanned are not listening.
-Web server found (80).
-NetBIOS Session Service found (139), probable unprotected Windows computer.

NUM

<http://www.netscantools.com>

Kỹ thuật quét port

Scanning Tools



Global Network Inventory Scanner

<http://www.magnetosoft.com>



AWSPS: UDP Scanner

<http://www.atelierweb.com>



Net Tools Suite Pack

<http://users.telenet.be>



AWPTA

<http://www.atelierweb.com>



Advanced Port Scanner

<http://www.radmin.com>



MegaPing

<http://www.magnetosoft.com>



Netifera

<http://netifera.com>

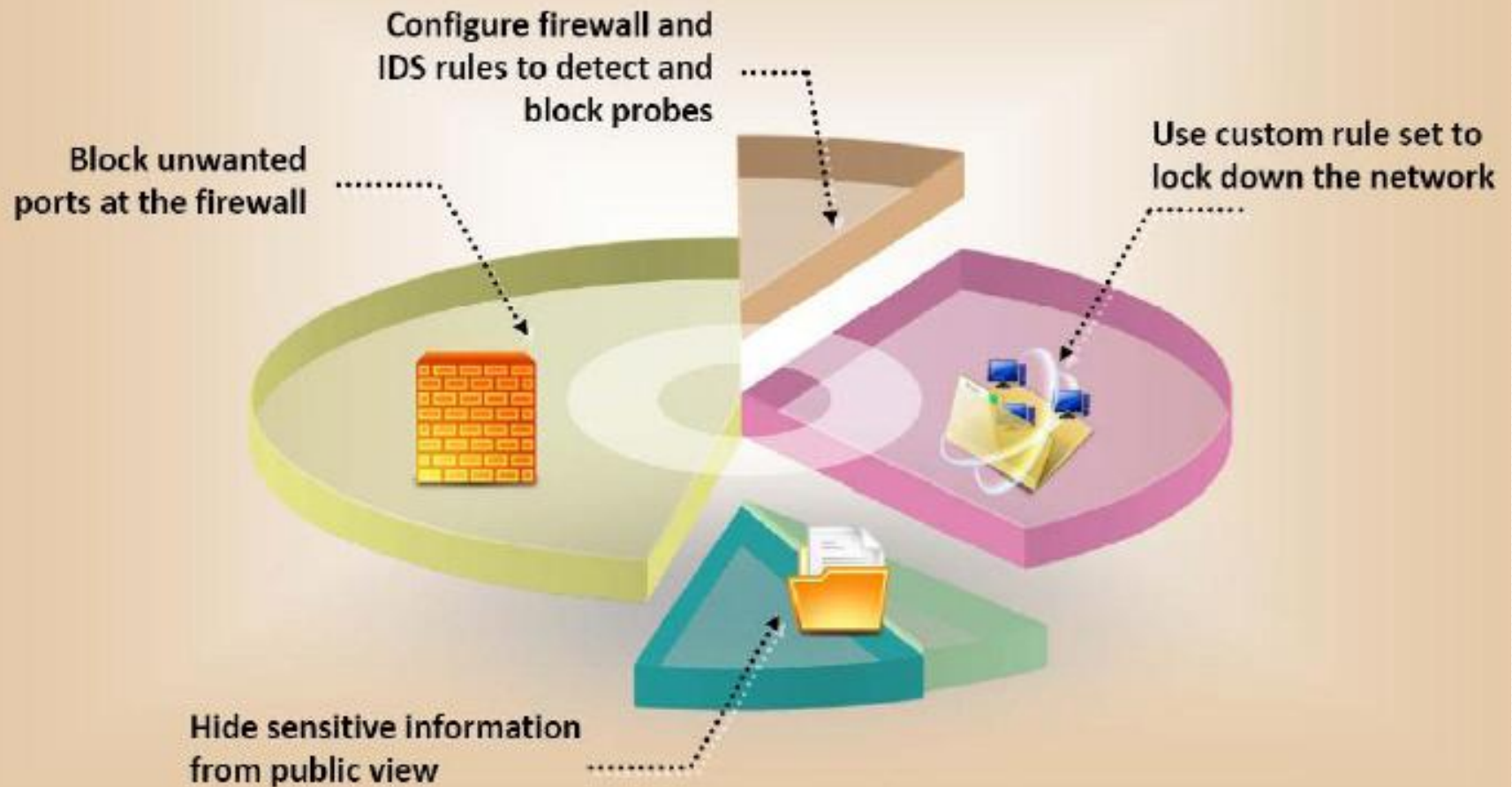


Network Inventory Explorer

<http://www.10-strike.com>

Biện pháp đối phó

Scanning Countermeasures



Vẽ lược đồ mạng

LANsurveyor

VisioLANsurveyor automatically discovers your network and **produces comprehensive and easy-to-view network maps** that can be exported into Microsoft Office

Features



- 1. Automatically discovers and diagrams network topology



- 2. Generates network maps in Microsoft Office® Visio®



- 3. Detects new devices and modifications in network topology



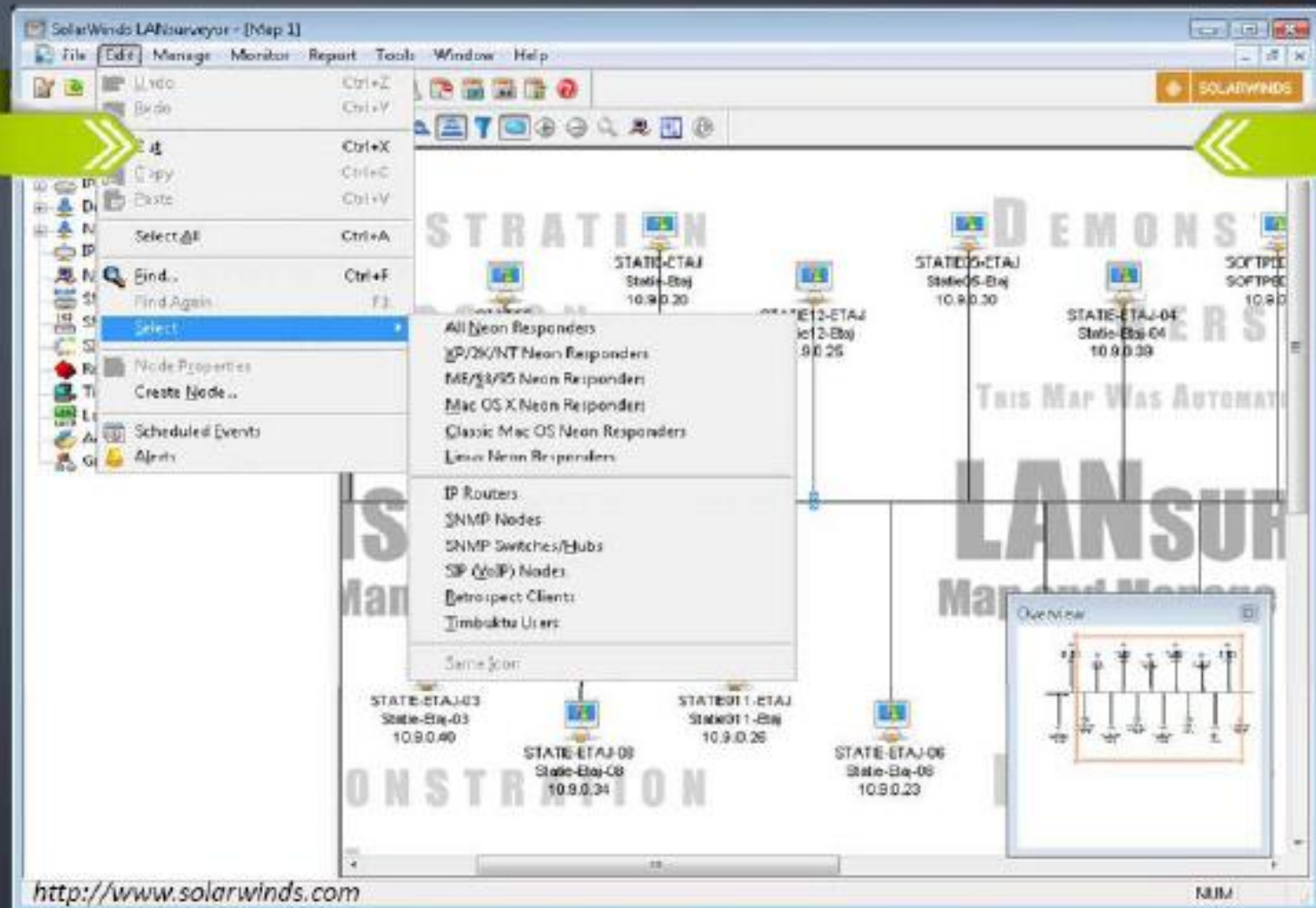
- 4. Performs inventory management for hardware and software assets



- 5. Directly addresses PCI compliance and other regulatory requirements

Vẽ lược đồ mạng

LANsurveyor: Screenshot



Vẽ lược đồ mạng

Network Mappers



LANState

<http://www.10-strike.com>



Insightix Visibility

<http://www.insightix.com>



FriendlyPinger

<http://www.killievich.com>



Ipsonar

<http://www.lumeta.com>



CartoReso

<http://cartoreso.campus.ecp.fr>



Lan-Secure Switch Center

<http://www.lan-secure.com>



HP OpenView Network Node Manager

<https://h10078.www1.hp.com>



NetMapper

<http://www.opnet.com>

Sử dụng Proxy

Proxy Servers

- Proxy is a network computer that can **serve as an intermediary** for connecting with other computers



Sử dụng Proxy

Why Attackers Use Proxy Servers?



To hide the **source IP address** so that an attacker can hack without any legal corollary



Attacker appears in a victim server's log files with a **fake source address of the proxy** rather than with the attacker's actual address



To **remotely access intranets** and other **website resources** that are normally off limits



To **interrupt all the requests** sent by an attacker and transmit them to a third destination, hence victims will only be able to identify the proxy server address

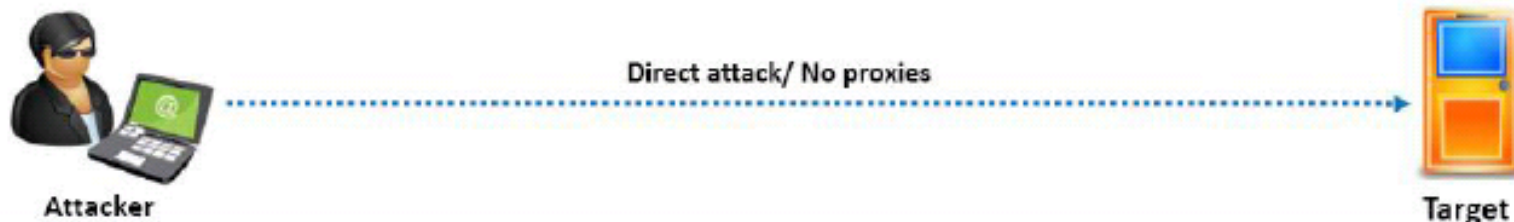


To use **multiple proxy servers for scanning and attacking**, making it difficult for administrators to trace the real source of attack



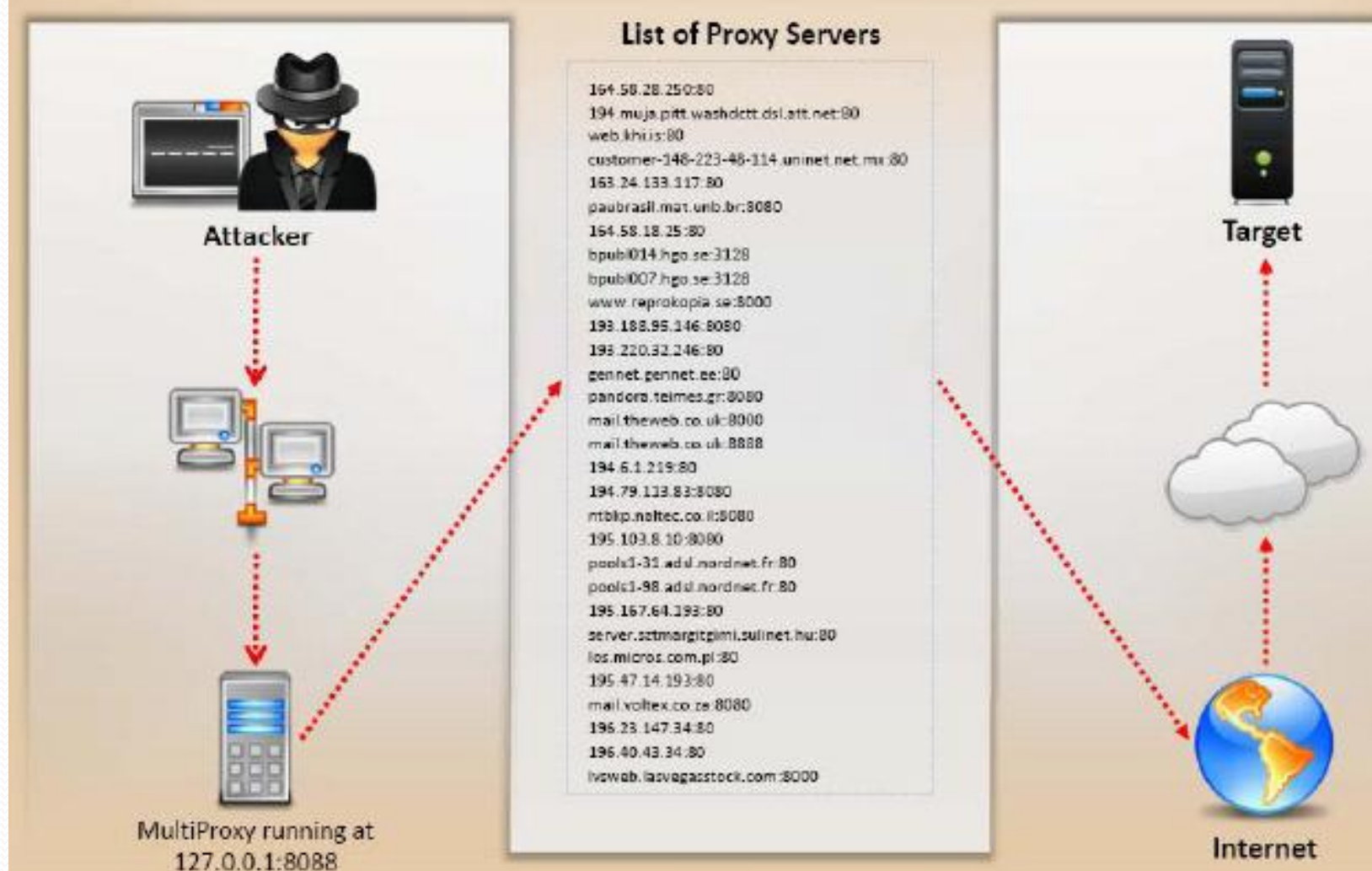
Sử dụng Proxy

Use of **Proxies** for Attack



Sử dụng Proxy

How Does **MultiProxy** Work?



Sử dụng Proxy

Free Proxy Servers

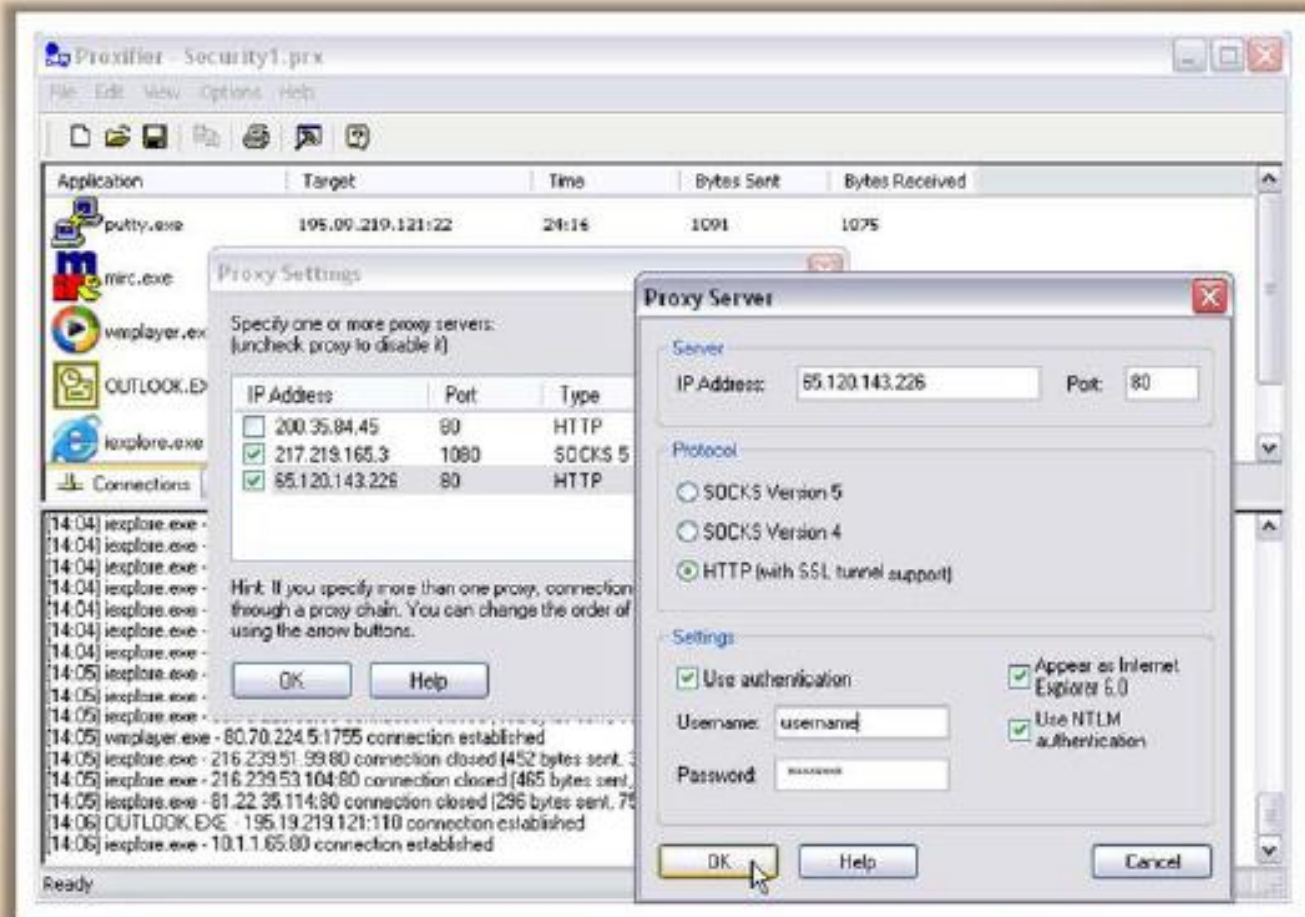


A search in Google lists thousands of free proxy servers

Sử dụng Proxy

Proxifier Tool: Create Chain of Proxy Servers

Proxifier is a program that allows network applications that do not support working through proxy servers to operate through an HTTPS or SOCKS proxy or a **chain of proxy servers**

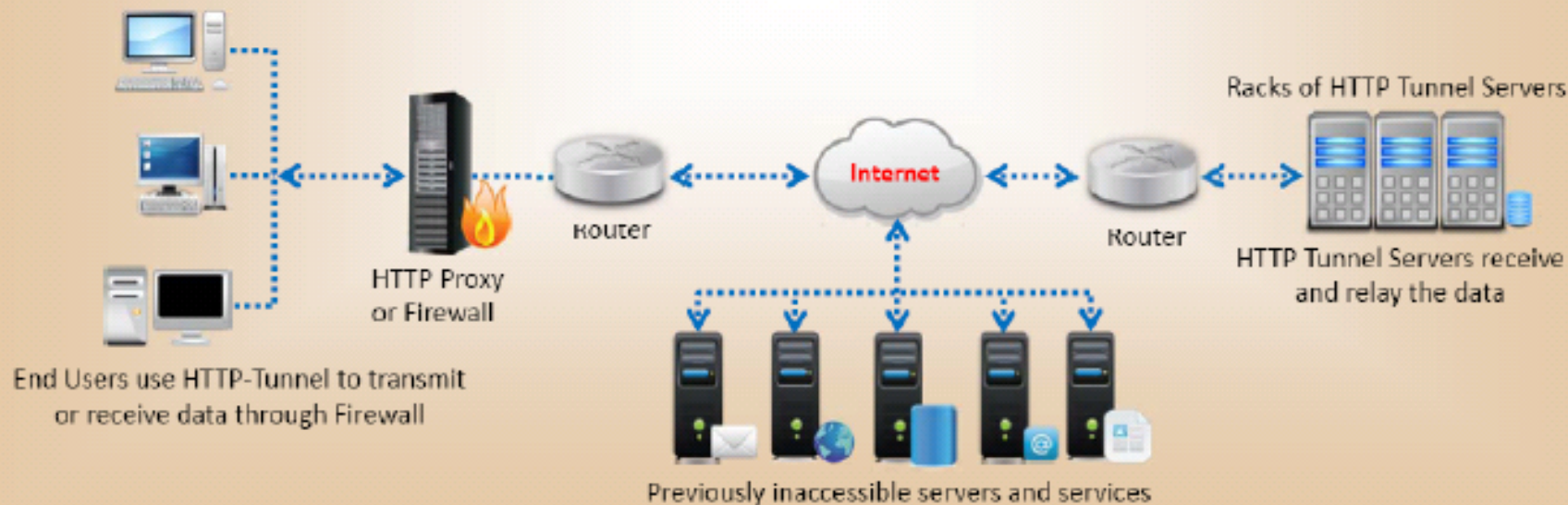


<http://www.proxifier.com>

Sử dụng Proxy

HTTP Tunneling Techniques

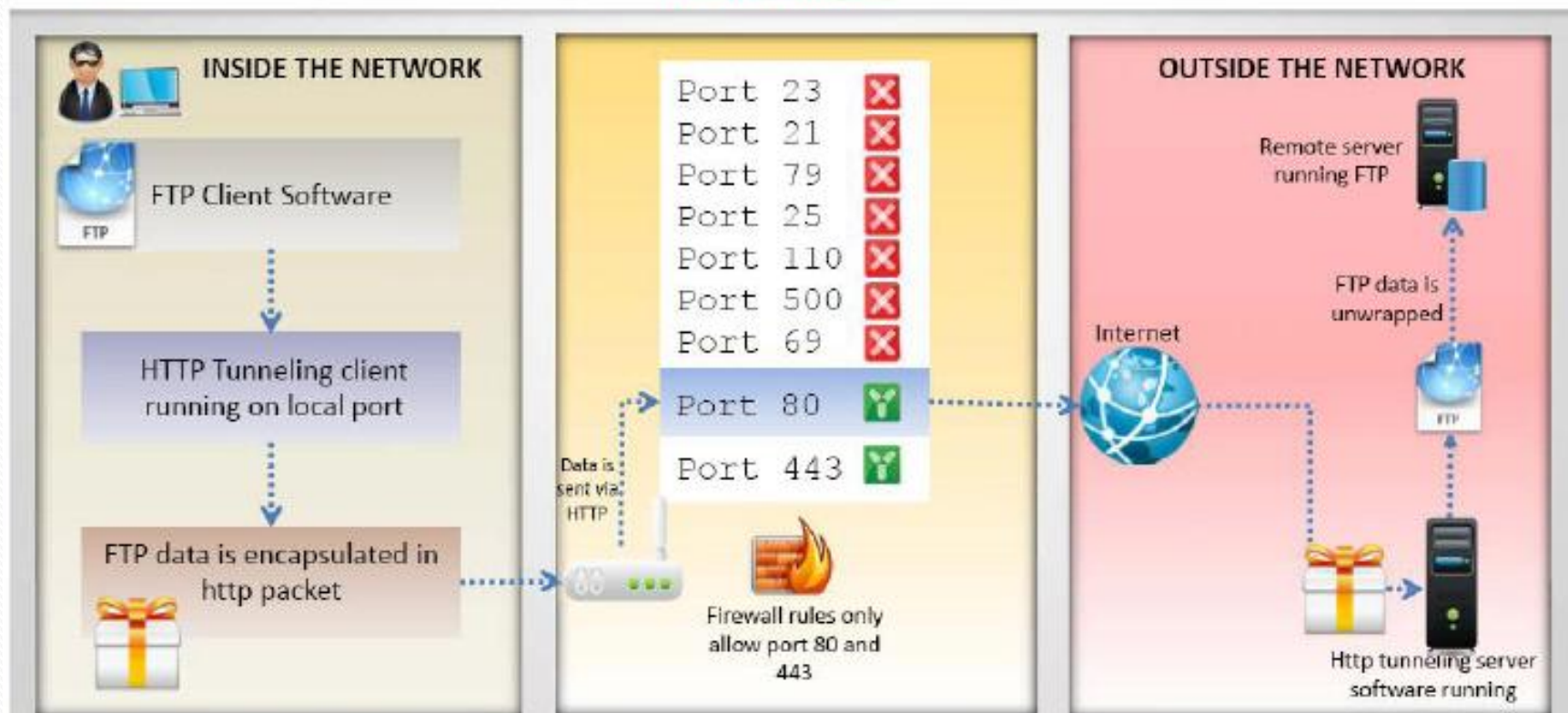
- HTTP Tunneling technology allows users to **perform various Internet tasks** despite the restrictions imposed by firewalls
- This is made possible by sending data through **HTTP (port 80)**



Sử dụng Proxy

Why do I Need HTTP Tunneling?

- If the organization has blocked all the ports in your firewall and only allows **port 80/443** and you want to use FTP to connect to some remote server on the Internet
- In this case, you can send your packets **via http protocol**



Sử dụng Proxy

Proxy Tools



Proxy Commander

<http://www.dlao.com>



GProxy

<http://gpass1.com>



Protoport Proxy Chain

<http://www.protoport.com>



Proxy+

<http://www.proxyplus.cz>



FastProxySwitch

<http://affinity-tools.com>



ProxyFinder

<http://www.proxy-tool.com>



ProxyFinder Enterprise

<http://www.proxy-tool.com>



**Proxy-Pro Professional
GateKeeper**

<http://www.sysgenic.com>

Ẩn danh

Anonymizers

- An anonymizer **removes all the identifying information** from the user's computers while the user surfs the Internet
- Anonymizers make **activity on the Internet untraceable**
- Anonymizer tools allow you to **bypass Internet censored websites**



Why use Anonymizer?



Ẩn danh

Anonymizers



Mowser

<http://www.mowser.com>



Anonymous Web Surfing Tool

<http://www.anonymous-surfing.com>



Hide Your IP Address

<http://www.hideyouripaddress.net>



JAP Anonymity and Privacy

<http://anon.inf.tu-dresden.de>



Anonymizer

<http://anonymizer.com>



The Cloak

<http://www.the-cloak.com>



IDsecure

<http://www.idzap.com>



Guardster

<http://www.guardster.com>

Địa chỉ IP giả

Spoofing IP Address

IP spoofing refers to the procedure of an attacker changing his or her IP address so that he or she appears to be someone else

When the victim replies to the address, it goes back to the spoofed address and not to the attacker's real address



IP spoofing using Hping2:

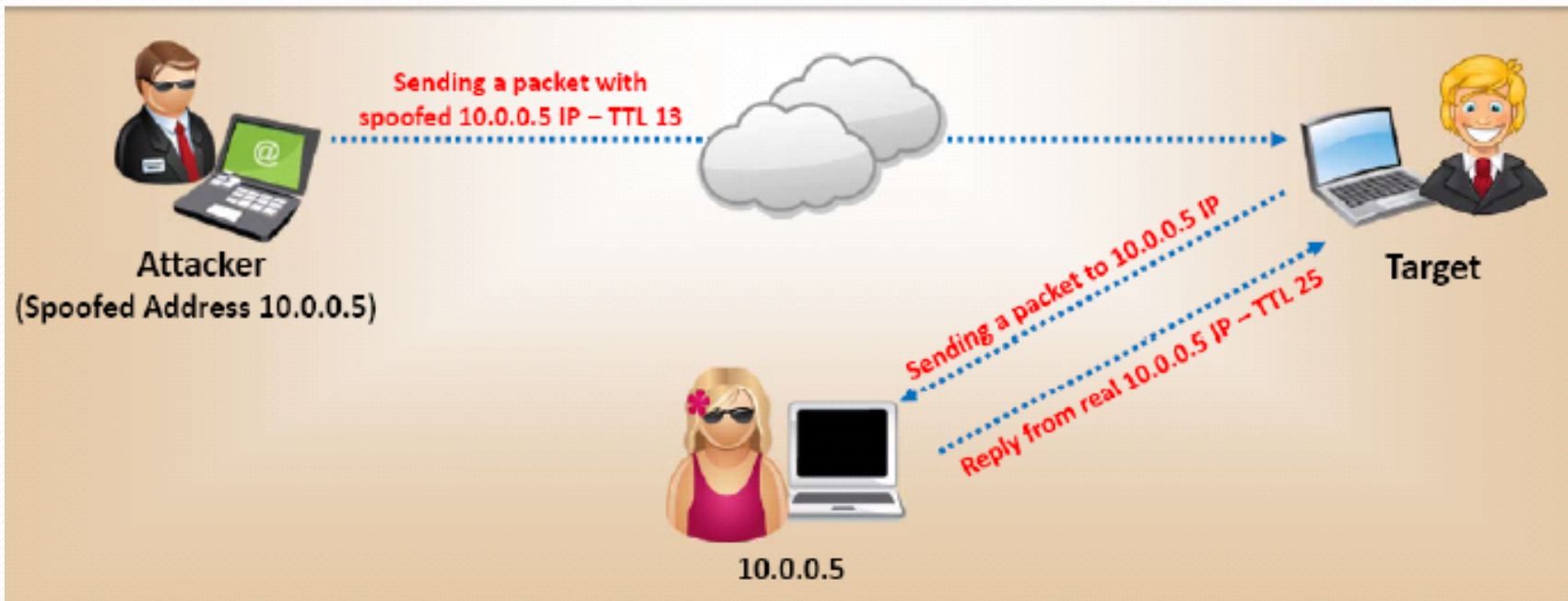
```
Hping2 www.juggyboy.com -a 7.7.7.7
```

You will not be able to complete the three-way handshake and open a successful TCP connection by spoofing an IP address

Địa chỉ IP giả

IP Spoofing Detection Techniques: Direct TTL Probes

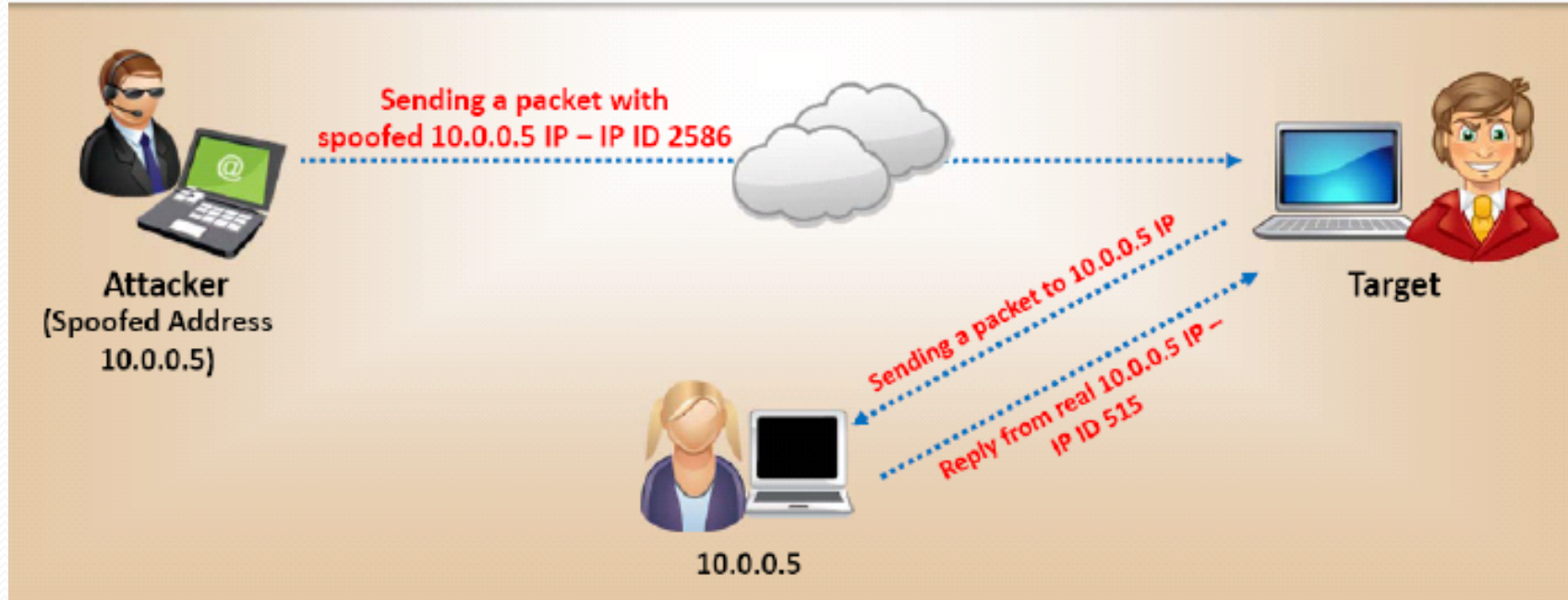
- ☐ Sending a packet to the claimed host will result in a reply, if the **TTL in the reply is not the same** as the packet being checked, it is a spoofed packet
- ☐ This technique is successful when attacker is in a **different subnet**



Địa chỉ IP giả

IP Spoofing Detection Techniques: IP Identification Number

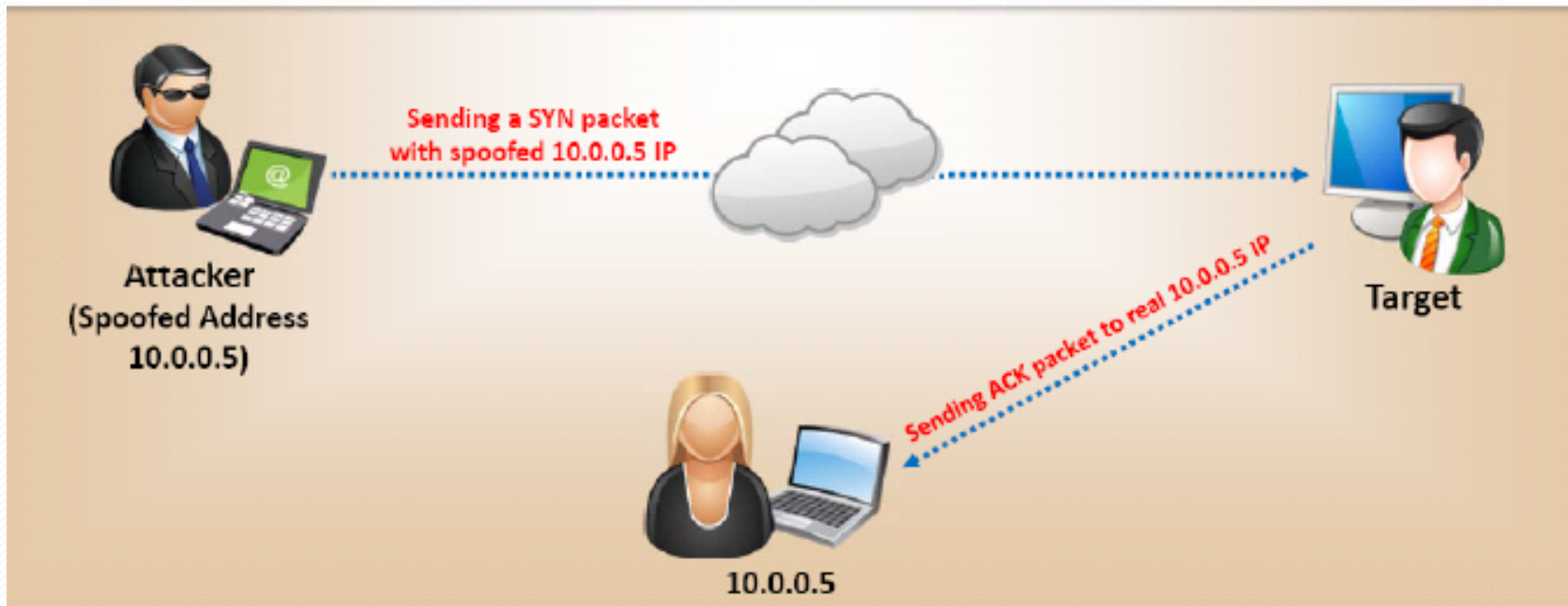
- Sending a probe packet to the claimed host will result in a reply, if the **IP ID number in the reply is not in the near value** as the packet being checked, it is a spoofed packet
- This technique is successful even if the attacker is in the **same subnet**



Địa chỉ IP giả

IP Spoofing Detection Techniques: **TCP Flow Control Method**

- If attacker is sending spoofed packets, he will not receive the **target's ACK-packets** and will not respond with SYN+ACK packet
- If the attacker does not stop sending packets after the initial window size is exhausted, most probably the **packets are spoofed**



Địa chỉ IP giả

IP Spoofing Countermeasures



Biện pháp phòng chống

Scanning Pen Testing

- The objective of penetration testing a network for scanning attempts is to determine the **network security posture** by identifying **live systems**, **discovering open ports**, **associated services** and **grabbing system banners** from a remote location simulating a network hacking attempt
- The penetration testing report will help **system administrators** to:



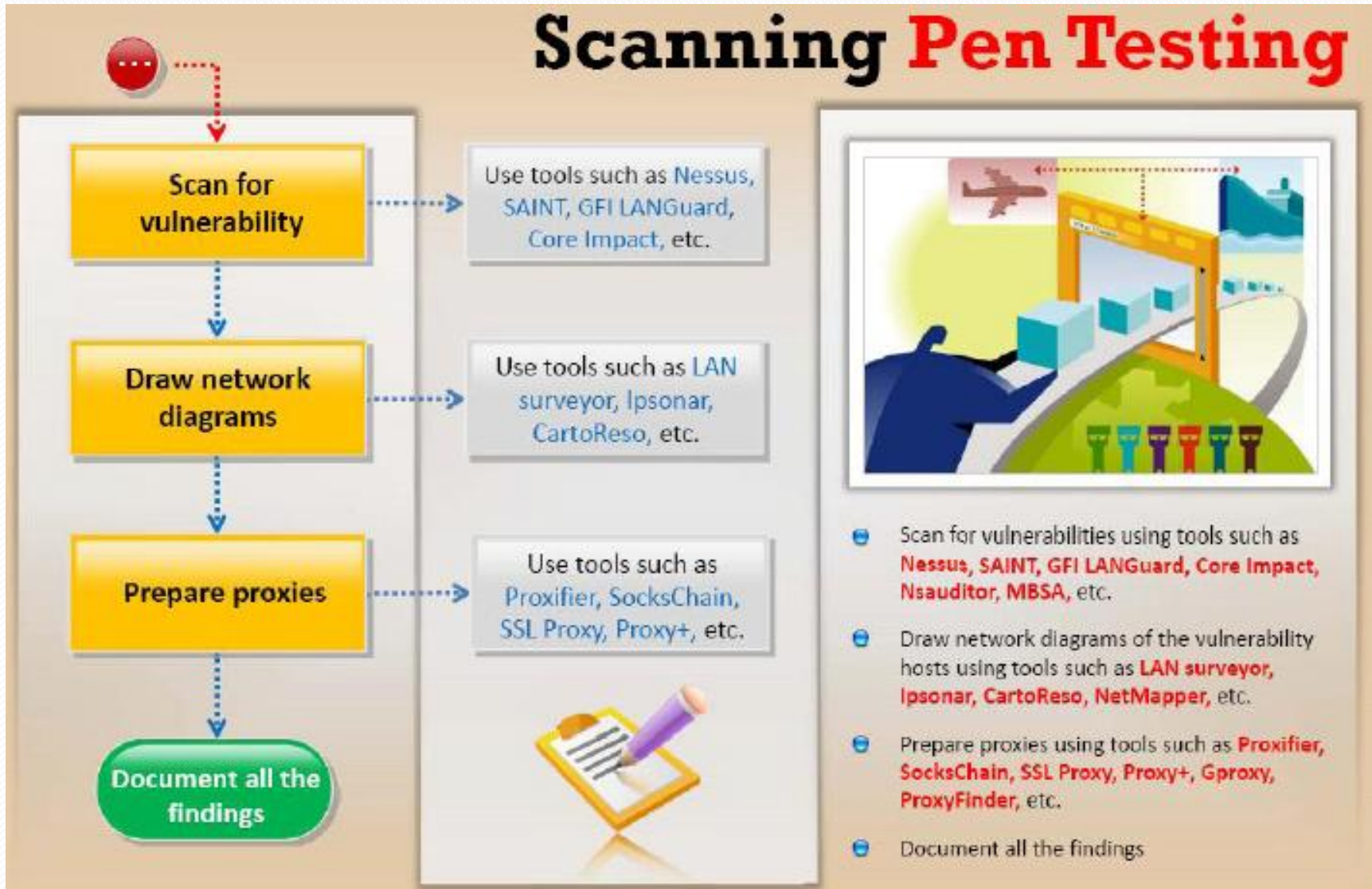
Biện pháp phòng chống

Scanning Pen Testing



Biện pháp phòng chống

Scanning Pen Testing



BÀI TẬP

1. Lập bảng tổng hợp các kỹ thuật quét mạng cơ bản (tên, đặc điểm, cách sử dụng, kết quả thu được...).
2. Proxy server là gì? Tại sao hacker sử dụng proxy server?
3. Trình bày các biện pháp phòng chống quét mạng.

Tên file: Bài tập 3B_họ_tên_mssv.doc